

CONTAINER: Bounding Credential-Compromise Impact in IEEE 2030.5 DER Systems

Huan Bui*

University of North Carolina at Charlotte, Charlotte, NC, USA

Abstract

IEEE 2030.5 binds a distributed energy resource’s long-lived bootstrap identity to its operational authorization and forbids online certificate revocation. A stolen credential therefore retains control authority indefinitely, and no online mechanism can withdraw it. We present CONTAINER, which replaces the conflated device credential with attested, short-lived, scope-bound operational credentials and uses non-renewal rather than revocation as the containment mechanism, deployable incrementally through native and gateway-proxy tiers. Because reachability alone does not distinguish these designs, we measure impact along four dimensions — cyber reach, state-dependent commandable flexibility, retained authority, and feeder consequence — and give a worked example of two compromises with identical reach but divergent flexibility, persistence, and feeder outcome. We implement a credential service with real X.509 and mutual TLS and a real OpenDSS feeder pipeline. On the IEEE 8500-node feeder, ten implemented security invariants pass, attested issuance costs about 0.23 ms, and a compromise under legacy authorization holds the feeder in violation for the full hour (integrated overvoltage 6956 p.u.-node-min) while CONTAINER’s scope and lifetime enforcement reduce this to 3.8 with recovery at credential expiry. These are reduced-scale pilot results; the pre-registered confirmatory sweep is future work.

*Corresponding author.

Email address: `hbui11@charlotte.edu` (Huan Bui)

Keywords: Critical infrastructure protection, distributed energy resources, IEEE 2030.5, remote attestation, authorization, cyber-physical security

1. Introduction

Distributed energy resources now participate in grid operations at a scale that makes their control interface a systemic concern. IEEE 2030.5 (Smart Energy Profile 2.0), profiled for distribution use by the Common Smart Inverter Profile (CSIP), is the application protocol through which utilities and aggregators dispatch inverter-based resources. An adversary who obtains a credentialed identity in this ecosystem does not merely read data; it can command real and reactive power on physical hardware connected to the grid.

Two properties of the IEEE 2030.5 trust model make this worse than a conventional credential-theft problem. First, the device’s bootstrap identity and its operational authorization are the same long-lived certificate: there is no separate, short-lived operational credential to lose. Second, the standard forbids certificate revocation; it directs that certificate authorities not maintain revocation lists or run status responders, and that clients and servers not check them [1]. A stolen credential is therefore valid until it expires, and its lifetime may be indefinite.

A natural objection is that this is a solved problem: model the DER authorization surface as a privilege graph and measure blast radius as reachability, as a mature line of work does for enterprise networks [2, 3, 4]. We argue this reduction is insufficient as ordinarily applied. What determines the damage of a DER compromise is not only which nodes an adversary can reach, but how much physical capacity those nodes command, how long the adversary retains that capacity, and what the feeder does in response under the grid state at the time. Reachability over a static privilege graph is a function of the attack locus and the graph alone; the quantities that matter are functions of the defensive policy and of exogenous physical state, and neither is topological.

Contributions

- *CONTAINER*, an incrementally deployable credential redesign for IEEE 2030.5 using attested, short-lived, scope-bound operational credentials, with non-renewal as containment and explicit session- and command-effect enforcement, deployable through native and gateway-proxy tiers.
- A *working prototype* — a credential service with real X.509 issuance, mutual TLS, and renewal, plus an OpenDSS feeder pipeline — with ten implemented security invariants verified and containment timing measured.
- A *pilot evaluation* on the IEEE 8500-node [5] and IEEE 123-bus feeders showing that scope bounds the instantaneous envelope while attested short lifetimes bound its duration, and that neither alone suffices.
- A *four-dimension impact model* (cyber reach, state-dependent commandable flexibility, retained authority, feeder consequence) making explicit which quantities a DER-authorization defense must move, with a worked example showing why unweighted static reachability cannot rank containment policies.

The threat model underpinning all four separates bootstrap identity, operational credential, and authorization scope, and names the baseline standard’s conflation of the first two as the driver of unbounded persistence.

We state scope plainly. The formal model, the separation propositions, and the cyber-side engine are implemented and covered by a regression suite, including the separating counterexample. The credential service and the feeder pipeline are implemented, and we report a pilot evaluation on the IEEE 8500-node feeder, confirmed on the IEEE 123-bus feeder: the results are measured but at reduced scale, two public feeders, one solver, up to ten seeds, on a workstation. The full pre-registered evaluation, with a cross-solver check, constrained hardware, and the full seed budget, is future work.

2. Background and Threat Model

2.1. Authorization in IEEE 2030.5 / CSIP

IEEE 2030.5 uses mutual TLS with X.509 device certificates. A device's identity is the certificate-derived LFDI/SFDI, and its authorization is scoped by a `FunctionSetAssignments` resource that binds it to one or more `DERPrograms`. Physical control authority is carried by the `DERControlBase` control modes: active-power capping (`opModMaxLimW`), signed fixed active power for storage charge and discharge (`opModFixedW`), reactive power (`opModFixedVar`, `opModVoltVar`), volt-watt and frequency-watt curves, and the hard connect and energize controls [6]. The standard specifies certificate-based authentication and function-set scoping; it does not mandate a single canonical access-control object.

2.2. Certificate validity and revocation

The trust model has two properties central to this work [1]. Device certificates have indefinite lifetime, and revocation is prohibited: certificate authorities are directed not to maintain revocation lists or run status responders, and endpoints are directed not to check them. The stated reasons against online revocation are concrete design constraints, not incidental: field devices have no guaranteed connectivity, a hard-fail check destroys availability while a soft-fail check is trivially bypassed by blocking the responder, revocation presupposes a secure time source that inverters may lack, and no party is defined as responsible for reporting a compromised device. The sanctioned substitute is a local allow or deny list. The consequence for our threat model is direct: once a credential is compromised, there is no online mechanism to withdraw it, so its authority persists until it expires.

2.3. Three separated layers

We separate three layers that the baseline standard conflates. *L1, bootstrap identity*: the hardware-rooted device certificate. *L2, operational credential*: the

credential that authorizes live sessions to an aggregator or DER management system. *L3, authorization scope*: the server-side binding from an identity to the function sets it may invoke. In baseline IEEE 2030.5, L1 and L2 are the same long-lived certificate, with no attestation gate and no revocation path. This conflation, not any single cryptographic weakness, is what makes a compromise persist for the certificate lifetime.

2.4. Compromise loci and adversary

We consider four compromise loci of increasing consequence: a single device, an edge gateway, an aggregator or DER management system, and a utility-side issuing role. The adversary obtains a valid credential at one locus (by key extraction, session theft, or a misconfigured or compromised server granting scope) and issues protocol-conformant control commands within that credential’s authorization. The adversary does not break TLS or the underlying cryptography. The utility-side issuing role is the ceiling on what any credential discipline can bound, because it can subvert issuance itself; we treat it as the boundary of the design’s protection rather than a case the design defeats.

2.5. Credential lifecycle and existing containment

The motivation depends on exact certificate-management behavior, which differs across editions: IEEE 2030.5-2018 [7], IEEE 2030.5-2023 [8] (which supersedes it, published December 2024), and the profile in force [9]. We separate four questions the literature tends to conflate: whether a certificate can be cryptographically revoked; whether a server can locally deny an identity despite a valid certificate; whether a device can be re-enrolled or re-keyed; and whether an active session or an already-issued control remains effective after credential expiry. Lack of CRL/OCSP bounds only the first. Table 1 lists the claims our argument uses and their current source of record; the revocation rows are sourced to the Sandia analysis, and the clause-level rows are marked pending direct verification against the applicable edition [1].

Table 1: Claims our argument uses and their current source of record. Rows marked “pending” are asserted on the 2018 edition and the Sandia analysis; the corresponding 2023 clause has not been read.

ID	Claim	Status
S1	Device certificate may be long-lived/indefinite	pending 2023 clause
S2	CRL use prohibited/unsupported	SAND §4.1; confirm 2023
S3	OCSP prohibited/unsupported	SAND §4.1; confirm 2023
S4	Local allow/deny listing available	SAND §4.1; confirm 2023
S5	Certificate replacement/re-enrollment possible	pending 2023 clause
S6	LFDI/SFDI derives from certificate	pending 2023 clause
S7	FunctionSetAssignments scopes operations	pending 2023 clause
S8	Scheduled DER controls can persist	pending 2023 clause

2.6. Assets, adversary, and goals

Protected assets: DER control integrity, fleet authorization, operational and attestation keys, and feeder stability and service continuity. *Adversary capabilities:* steals an operational key (and, where tested, a bootstrap key), compromises firmware, steals an active session, compromises a gateway or aggregator, issues protocol-conformant commands, and observes authorized telemetry. *Exclusions:* breaking standard cryptography, physical destruction, and compromising both the root issuer and all audit controls, which we treat as the protection boundary rather than a defended case. *Security goals:* least authority, bounded new-session authority, bounded active-session authority, bounded command-effect duration, fresh-key containment, replay resistance, safe degradation, and auditability. *Non-goals:* defending against malicious root issuance without added governance, detecting every hardware attack, replacing grid protection, and proving safety for every feeder.

3. The Four-Dimensional Authorization-Compromise Impact Model

We model the impact of an authorization compromise along four dimensions rather than a single scalar radius, because the four quantities have different mathematical types: a set, a state-dependent power region, a set of durations, and a feeder-physics functional. We keep the BR notation for continuity but describe each as a dimension.

Substrate.. A static privilege graph $G = (V, E)$ has principals and resources as nodes and access relations as edges; it is a snapshot with no time axis and no physical state. A compromise $x \subseteq V$ is a set of compromised credentials. A protection policy $\pi = (L, \text{Att}, A)$ encodes a credential-lifetime function L , an attestation-gated renewal predicate Att , and an authorization scope map A . The device and grid operating state at time t is $u_t \in U$, and F is the feeder power-flow and protection model; neither u_t nor F appears in G .

Cyber reach (BR_{reach}).. The set of principals, resources, or DER endpoints to which the compromised authority can submit an authenticated request, $\text{ReachSet}(x, \pi)$, the least fixed point of the π -enabled access relation from x . We report reachable principals, reachable DERs, reachable sites, the fraction of fleet, and the authorization paths by compromise locus. Reach is a cyber quantity: reaching a server is not the same as controlling a physical resource, and we keep the two separate.

Commandable flexibility (BR_{flex}).. Capacity is state dependent, so we define it through a feasible command set rather than nameplate. For DER d at time t ,

$$\mathcal{C}_d(t; u_t, A_\pi(d)) \tag{1}$$

is the set of set-points an adversary holding scope $A_\pi(d)$ can command given the device and grid state u_t : present set-point, state of charge, irradiance, inverter apparent-power and ramp limits, and availability. The aggregate reachable flexibility over the reachable DERs is the achievable active- and reactive-power

intervals $[\Delta P^-, \Delta P^+]$ and $[\Delta Q^-, \Delta Q^+]$. A conservative scalar for tables is

$$\text{BR}_{\text{flex}}(t) = w_P(\Delta P^+ - \Delta P^-) + w_Q(\Delta Q^+ - \Delta Q^-), \quad (2)$$

with weights w_P, w_Q stated wherever the scalar is used; the implementation retains the full vector and region. Read-only or empty scope yields the singleton current set-point, hence zero flexibility.

Retained authority (BR_{auth}) and *exposure* (BR_{exp}).. Certificate lifetime alone understates persistence, so we separate three components: T_{cred} , the time until the stolen operational credential is no longer accepted for a new session; T_{sess} , the time until sessions authenticated with it can no longer issue commands; and T_{cmd} , the time until queued, scheduled, or latched controls cease to affect the DER. Effective retained authority is

$$\text{BR}_{\text{auth}} = \max(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}}), \quad (3)$$

and the more informative capacity-time exposure is

$$\text{BR}_{\text{exp}} = \int_{t_0}^{t_{\text{end}}} \text{BR}_{\text{flex}}(t) \mathbf{1}[\text{adversarial authority effective at } t] dt, \quad (4)$$

in kW·h or kVar·h. This distinction matters: certificate expiry does not by itself end an open session or an already-issued long-duration control, so a design that shortens T_{cred} without enforcing T_{sess} and T_{cmd} does not bound exposure.

Physical consequence (BR_{phys}).. Physical consequence is the worst outcome an adversary can drive within its authority over a horizon H . For an attacker action trajectory $a_{0:H} \in \mathcal{A}(x, \pi, u_{0:H})$ constrained to authorized functions and device limits,

$$\text{BR}_{\text{phys}} = \max_{a_{0:H} \in \mathcal{A}} J(F, u_{0:H}, a_{0:H}), \quad (5)$$

where J is a declared impact objective. Our primary objective is the voltage-violation area, the node-time outside the allowed band weighted by magnitude: for node n with voltage $V_n(t)$ and bounds $V_{\min}, V_{\max}$,

$$J_V = \sum_{n,t} \left[\max(0, V_n(t) - V_{\max}) + \max(0, V_{\min} - V_n(t)) \right] \Delta t. \quad (6)$$

Table 2: The four impact dimensions.

Dim.	Type	Unit	Computation
BR_{reach}	set	count	fixed point of π -enabled access from x
BR_{flex}	interval	kW, kVAr	$\sum_d \mathcal{C}_d(t; u_t, A_\pi(d))$ over reachable DERs
BR_{auth}	duration	s	$\max(T_{\text{cred}}, T_{\text{sess}}, T_{\text{cmd}})$
BR_{phys}	scalar	p.u.-node-min	$\max_a J_V(F, u, a)$ over the feeder model

Secondary metrics are maximum per-unit deviation, violating-node count, protection trips, regulator tap operations, energy not served, unnecessary curtailment, and recovery time. We report both a worst-case optimizing attacker and an operationally realistic attacker that uses only telemetry available through the compromised authority, so the paper does not report only an omniscient upper bound.

Table 2 summarizes the four dimensions, their mathematical types, units, and computation. The distinct types are the reason we present them as dimensions rather than forcing a single scalar radius.

4. Why Reachability-Only Measurement Is Insufficient

We do not claim that no graph model can represent time or physical impact; temporal, probabilistic, and attributed cyber-physical attack-graph models exist and can encode some of these quantities. Our claim is narrower and, we argue, more defensible:

Static, unweighted reachability is insufficient to compare DER credential-containment policies, because it omits authorization scope, temporal validity, active-session and command persistence, state-dependent device flexibility, and feeder state.

Formally, call a measurement *reachability-only* if it is a function M of the unchanged reachable-node set $\text{ReachSet}(x)$ alone. Since $M(\text{ReachSet}(x))$ is single-valued in $\text{ReachSet}(x)$, any two configurations that share $\text{ReachSet}(x)$ but differ in an impact dimension refute the adequacy of every reachability-only M . We give three such separations. Each is accompanied by a constructive counterexample that ships as a regression test in the released analysis engine, so the claims are checkable rather than rhetorical.

Proposition 1 (scope separation).. There exist policies π_1, π_2 and a compromise x with $\text{ReachSet}(x, \pi_1) = \text{ReachSet}(x, \pi_2)$ but $\text{BR}_{\text{flex}}(\pi_1) \neq \text{BR}_{\text{flex}}(\pi_2)$. *Construction*: hold the reachable DER set fixed and vary only the scope map A , granting control function sets under π_2 and read-only status under π_1 at the same nodes. The feasible command sets, and hence the flexibility intervals, differ. *Interpretation*: scope, not reach, sets how large a lever the adversary holds.

Proposition 2 (temporal separation).. There exist credential and session policies with equal initial reach but different retained-authority trajectories, hence different BR_{auth} and BR_{exp} . *Construction*: an ephemeral attestation-gated credential loses acceptance at the next un-attested renewal, while a long-lived unrevoked credential retains it; identical reach, different $\int \text{BR}_{\text{flex}} \mathbf{1}[\text{effective}] dt$. A static snapshot has no time coordinate to express this. *Interpretation*: persistence is a property of the graph’s trajectory over time, not of a single snapshot.

Proposition 3 (physical-state separation).. There exist feeder states u_1, u_2 with identical cyber authorization but different physical outcomes, hence $\text{BR}_{\text{phys}}(u_1) \neq \text{BR}_{\text{phys}}(u_2)$ at fixed x and π . *Construction*: the same authorized curtailment relieves an overvoltage at one operating state and drives a reverse-power protection trip at another. No privilege graph contains u or F . *Interpretation*: realized consequence depends on feeder physics and operating conditions that are outside any authorization model.

Table 3: Impact dimensions versus reachability-only metrics.

Dimension	Closest metric	What reachability-only omits
BR_{reach}	logical reachability [2]	(overlap; the cyber-reach dimension)
BR_{flex}	weighted reachability [3]	scope and device/grid state at fixed reach
BR_{auth}	k -zero-day safety [4]	credential, session, and command time
BR_{phys}	impact metric on reach	exogenous state u and feeder physics F

Table 3 summarizes, for each dimension, the closest classical metric and what a reachability-only reading omits. The three classical metrics are static-snapshot and cyber-only.

Worked counterexample.. Two compromises reach an identical DER set D : one 20 MW battery and ten rooftop PV under a common aggregator. Their reachable sets are identical, as is every topological reach metric. They differ only in policy and grid state (Table 4). Extending a classical graph to distinguish them requires resource-by-scope product nodes, a time index, and attached u and F ; that extension is precisely the policy-and-state model of Section III, so it agrees with our claim rather than refuting it, and such extended models are complementary to, not the same as, reachability-only measurement.

We use the propositions to motivate the model, not to dominate the paper: the contribution is the containment system and its measured evaluation, and the separations say which quantities that evaluation must move.

5. CONTAINER Design

CONTAINER separates the layers that IEEE 2030.5 conflates and enforces credential lifetime at the session and command layers, not only at issuance. The design is a containment chain: fresh attestation, a fresh hardware-bound key, a short scoped operational credential, a bounded session, and a bounded command

Table 4: Two compromises with identical topological reach.

	α (attested, ephemeral)	β (legacy, long-lived)
Reachable set	D (identical)	D (identical)
Scope A_π	volt-var on PV; read-only battery	full DERControl incl. battery
Lifetime	6 h, attestation-gated	indefinite; no revocation
BR_{flex}	tens of kVar	tens of MW
BR_{exp}	bounded (hours)	up to the cert lifetime
BR_{phys} at a vulnerable u	negligible	protection trip / excursion

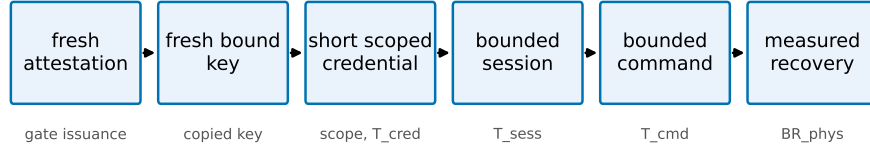


Figure 1: The CONTAINER containment chain. Each link bounds a dimension: attestation gates issuance, fresh-key binding contains a copied key, scope and short lifetime bound BR_{flex} and T_{cred} , session and command enforcement bound T_{sess} and T_{cmd} , and measured recovery bounds BR_{phys} .

effect, so that removing authority actually removes control. Each link targets a dimension of the model (Fig. 1).

5.1. Components and trust layering

The device keeps a long-lived, hardware-rooted bootstrap identity [10] used only for enrollment and attestation, never accepted directly for DER control. An *attester* produces fresh evidence bound to a freshly generated operational public key; a *verifier* checks evidence against endorsement and reference values and returns an explicit result; a *credential issuer* signs a short-lived operational certificate embedding role, site, scope, and expiry only for a valid attestation result; an *authorization service* maps the operational identity to least-privilege

function-set assignments; the *2030.5 server or proxy* authenticates the operational certificate, enforces a maximum session age, and rechecks authorization per command or at a bounded interval; a *session controller* and a *command-lifecycle controller* bound authority beyond expiry; and a *risk controller* selects deny, scope narrowing, or bounded emergency renewal. We use the Entity Attestation Token [11] under the RATS Attester/Verifier/Relying-Party model [12], and define a concrete EAT profile rather than treating EAT as a complete attestation protocol.

5.2. Fresh-key binding

Attesting a device is not sufficient: a healthy device can pass attestation while an attacker retains a previously copied operational key. CONTAINERD therefore requires that every credential epoch use a newly generated operational key, generated in a TPM, TEE, or secure element where available and marked non-exportable, whose public-key digest is carried in the attestation evidence. The issuer signs only the attested public key, refuses renewal that presents only a prior certificate, rejects replayed evidence and reused nonces, and rotates the key even when the device stays healthy. This is what contains a copied key across the next epoch.

5.3. Session and command-effect enforcement

Certificate expiry does not end an open TLS session or an already-issued long-duration control. CONTAINERD closes sessions at credential expiry (or bounds session age to the credential TTL) and revalidates authorization per command, and it bounds adversary-issued controls through a maximum command duration, cancellation on containment, and safe-default restoration, with explicit handling of scheduled DERControls. The two quantities the prototype measures are

$$\Delta_{\text{expiry}} = t_{\text{last adv. command}} - t_{\text{expiry}}, \quad (7)$$

$$\Delta_{\text{effect}} = t_{\text{effect ends}} - t_{\text{expiry}}, \quad (8)$$

Table 5: Safe-mode authorization states.

State	Allowed	Denied
Healthy	normal scoped control	out-of-scope control
Verification delayed	read telemetry, hold last safe schedule	new high-impact dispatch
Attestation uncertain	read-only, bounded emergency control	arbitrary set-points
Known compromise	read-only or total denial	all control
Issuer outage	prior low-risk scope, bounded grace	scope expansion, high impact

each targeted to zero or a small declared bound. These are exactly the T_{sess} and T_{cmd} components of BR_{auth} .

5.4. Safe-mode policy

Failure behavior is explicit rather than fail-open. The risk controller chooses among the states in Table 5; no failure mode grants indefinite authority, and the safety of each degraded state is validated under feeder conditions rather than assumed.

5.5. Migration compatibility

We separate three compatibility levels, and the protocol requires a passing interoperability test before any of them is claimed, rather than asserting “backward compatible.” None has yet been tested; Section 9 reports interoperability as untested. *Protocol compatibility*: 2030.5 messages remain standard conformant. *Implementation compatibility*: unmodified client or server software can participate. *Deployment compatibility*: legacy and upgraded devices coexist. Three tiers realize this: a bootstrap-only legacy tier, a gateway-attested proxy tier where an edge gateway holds the operational credential for downstream legacy devices, and a native device-attested tier. We claim only the compatibility level demonstrated by an interoperability test; if only the proxy

tier interoperates with an unmodified endpoint, we say CONTAINERDER supports incremental deployment through a credential-terminating gateway proxy, and no more.

5.6. Implementation status

The design is realized as an issuance and renewal service using real X.509 certificates and mutual TLS, with a Python IEEE 2030.5-style client in place of the EPRI C client and structured event logging for every credential, session, and command transition. Its security invariants and workstation overhead are reported in Section 9; a native EPRI-client integration and constrained-hardware measurements remain future work.

6. Cyber-Side Analysis Engine

We implement the cyber-side impact dimensions as an analysis engine, `pkimodel`, that computes BR_{reach} , BR_{flex} , and BR_{auth} for a compromise locus under a policy. The engine models the identity and delegation graph over the six node types of the threat model, with typed issuance, delegation, and authorization edges. Its central modeling choice follows the formalism: a credential’s reach (which DERs it can address) is represented independently of its scope (which function sets it may invoke at each DER). This is what makes the separating counterexample expressible in code, and we ship that counterexample as a regression test: the two compromises resolve to an identical reachable set of eleven DERs, yet the engine computes zero commandable kW for the attested credential against tens of MW for the legacy one, and a persistence of hours against the analysis horizon.

The authorization policy is parameterized, not fixed. A hardcoded permissive access model would overstate what a stolen certificate can command, so the engine exposes four ACL realism levels spanning single-device, site, feeder-segment, and whole-aggregator-fleet scope, and these are varied in the evaluation. On a synthetic 200-device fully-central fleet spread over four feeders,

the reachable-DER count grows from one (single-device) to one (site) to fifty (feeder) to two hundred (fleet), and commandable capacity grows in step. The feeder-level figure is the fleet divided by the feeder count, so it moves with that generator parameter; the parameters are released with the artifact. This decomposition operationalizes RQ1: most of the reach gained by a compromise is attributable to authorization scope rather than to authentication alone. The retained-authority dimension is returned as a distribution over duration rather than a point estimate, reflecting the stochastic outcome of attestation-gated renewal, and it separates credential, session, and command-effect components rather than reporting certificate lifetime alone.

The engine consumes synthetic scenarios from a deterministic, seedable generator, since real utility authorization graphs are not public; the generator is released as part of the artifact. The engine is cyber-side only. It produces the reachable-DER set and the commandable-capacity envelope that the feeder co-simulation consumes to compute BR_{phys} .

7. Feeder Co-Simulation Methodology

The physical consequence dimension is measured by a feeder co-simulation that translates an authorized-control reach from the analysis engine into a malicious dispatch program and runs it on a public distribution feeder. We take the IEEE 8500-node feeder [5] as the primary benchmark and the PNNL 9500-node system [13] as an advanced validation tier. Time-series inputs come from public solar and load datasets. This part of the work is methodologically routine relative to the false-data-injection literature on distribution systems, so we build it to be unimpeachable rather than novel.

Two choices harden the protocol against the standard objections to simulation studies. First, the protocol specifies a GridLAB-D cross-check on the base case and one attack case, following the precedent of the PNNL 9500 report [13]; it is not yet implemented, and any divergence it reveals will be reported rather than suppressed. Second, the full design gates dispatch on credential state

through a HELICS federation. The present implementation applies the authorization envelope directly in the OpenDSS driver, which enforces the same constraint without the federation. Of this protocol, the OpenDSS single-solver path is implemented and exercised in Section 9; the HELICS federation and GridLAB-D cross-check are specified here and not yet built. The attack families are volt-var curve distortion, volt-watt curve distortion, export-limit distortion, and curtailment spam. The metrics are the count of nodes violating the ANSI C84.1 bands [14], maximum voltage deviation, the area under the violation curve over time, regulator tap operations, unnecessary curtailment, energy not served, and recovery time to steady limits, with the per-unit voltage excursion as the primary continuous measure and a protection-trip flag as the discrete outcome.

We do not tune feeder parameters to amplify impact; we report what the standard models produce. The clean base case, the four attack families, the eight metrics, and the cross-solver agreement are the acceptance criteria for this component. As with the credential service, a first benchmark run on the IEEE 8500-node feeder appears in the pilot evaluation; the full sweep on both feeders, with the GridLAB-D cross-check and seasonal operating states, follows the pre-registered protocol chosen in advance.

8. Evaluation Protocol (Pre-Registered)

No measured results are reported in this section. We state the evaluation protocol, which is frozen and content-hashed before any run and will be deposited on a trusted timestamped repository before the confirmatory sweep; at present the immutability evidence is the content hash recorded in `PREREGISTRATION.md`, together with the version-control commit under which that record was placed. The design therefore cannot be adjusted after seeing outcomes without leaving a visible trace. Chronologically, the measured results in Section 9 are pilot experiments; the confirmatory scenario matrix and statistical plan were frozen and hashed after the pilots, and pilot observations are excluded from the con-

Table 6: Credential-lifecycle baselines. FK = fresh key per epoch; Sess = session enforcement; Cmd = command-effect cleanup.

ID	Design	Lifetime	Attestation	Scope	FK	Sess	Cmd
B1	legacy identity-as-authority	long	no	deployment ACL	no	no	no
B2	legacy + narrow ACL	long	no	narrow	no	no	no
B3	ephemeral-only	short	no	reference	opt.	expiry	opt.
B4	attestation-only	long	yes	reference	enroll	weak	no
B5	full CONTAINER	short	yes	narrow	per-epoch	yes	yes
B6	CONTAINER safe-mode	short	yes	narrow/degraded	per-epoch	yes	yes

firmary tests.

Baselines and mechanism ablations.. Six credential-lifecycle designs are compared: legacy identity-as-authority (B1), legacy with a narrow access list (B2), ephemeral-only (B3), attestation-only (B4), full CONTAINER (B5), and safe-mode renewal (B6). Each baseline is specified by explicit fresh-key, session-enforcement, and command-cleanup attributes, because the central claim is that short lifetime alone does not contain a copied key, an active session, or a persistent command. Eight mechanism ablations (A1–A8) each remove one link of the containment chain, so the measured reduction is attributed to a mechanism rather than to shorter certificates. Table 6 gives the baseline mechanism attributes.

Factors and design.. The factors are credential time to live, authorization scope, compromise locus (with the issuer treated as a trust boundary, not a defended case), DER penetration and technology mix, attack program, attestation-trust state, renewal policy, and operating state. Every attack runs under both a worst-case optimizing attacker and an operationally realistic telemetry-limited attacker, so no result is only an omniscient upper bound. The primary comparison is the fully-crossed lifetime-by-scope factorial, whose interaction term is the compositional claim.

Statistics.. The experimental unit is the complete paired scenario run, not the per-timestep sample. The primary voltage-violation area is analyzed with a

mixed-effects model, $\log(1 + Y) = \beta_0 + \beta_1 \log(\text{TTL}) + \beta_2 \text{Scope} + \beta_3 \log(\text{TTL}) \times \text{Scope} + b_{\text{day}} + b_{\text{seed}} + \epsilon$, with the interaction coefficient testing the primary hypothesis and robust, aligned-rank, or permutation fallbacks where assumptions fail. Protection trips use mixed-effects logistic regression, violating-node counts a negative-binomial mixed model, and recovery time survival analysis. Effect sizes are the median paired difference, the ratio of geometric means, the paired rank-biserial correlation, and odds ratios, each with bootstrap confidence intervals, and Holm correction is applied within, not across, hypothesis families. A five-seed pilot and a simulation-based power analysis set the production seed count before final comparisons are viewed. These inferential procedures apply to the confirmatory sweep, not to the pilot in Section 9: the stored pilot data support medians and interquartile ranges over seeds, which is what that section reports, but they do not support the mixed-effects estimates, bootstrap intervals, or family-corrected p -values specified here, and none are claimed.

Pre-registered hypotheses and honesty rule.. The primary hypothesis is a non-additive lifetime-by-scope interaction on voltage-violation area. Secondary hypotheses cover capacity-time exposure reduction, the advantage of the full design over both the ephemeral-only and attestation-only ablations, the reduction of post-expiry residual authority by session and command enforcement, locus dominance, the safe-mode availability tradeoff, fresh-key containment of a copied key, and the renewal-latency safety margin. The full design must reduce capacity-time exposure and voltage-violation area on at least one public feeder, which is the study’s go/no-go gate. The expected-pattern statement records what we anticipate; any deviation, including a weak physical effect on a robust feeder, is reported rather than engineered away, and severe or nonconverging runs are never silently dropped.

9. Pilot Evaluation

We report a pilot evaluation that exercises the full pipeline end to end and produces measured results. Its scope is deliberately limited and stated plainly:

Table 7: Implementation and evaluation status.

Component	Status
Cyber-side analysis engine	implemented, measured
Credential service (issuance, fresh key, session/command enforcement)	implemented, measured
Feeder co-simulation (OpenDSS, two feeders)	implemented, measured
Availability fault injection	implemented, measured
Native EPRI-client 2030.5 traffic	planned
Constrained-hardware / TEE attestation	planned
GridLAB-D cross-solver check	planned
HELICS federation for dispatch gating	planned
Interoperability tests	planned
Full pre-registered sweep	planned

a workstation platform (no constrained hardware), the real IEEE 8500-node feeder [5] as a first benchmark run but not yet the PNNL 9500 system, a single solver (OpenDSS, no GridLAB-D cross-check), load-state snapshots rather than a full seasonal time series, one PV penetration level, a fixed rather than per-state-optimized attacker, and a Python IEEE 2030.5-style client in place of the EPRI C client. These results establish that the mechanism and the measurement work; the pre-registered full-scale sweep is not replaced by them. Table 7 states the status of each component.

Throughout, the primary physical endpoint is the *induced overvoltage area* ΔJ_V : the attack-case value of the one-sided overvoltage term of J_V , summed over all energized nodes as $\sum_i \max(0, V_i - 1.05)$, minus its value in the base case at the same load state. Positive values mean the attack pushed nodes above the ANSI C84.1 upper band [14]; values at or below zero mean it did not. A single power-flow solution therefore yields ΔJ_V in per-unit nodes (p.u.-node), and the time-series experiment reports the same quantity integrated over a one-minute time step, in per-unit node-minutes (p.u.-node-min). We label each table and figure with the unit it carries.

Functional invariants and containment (C1, C2)... The credential service uses real X.509 / ECDSA certificates and an EAT-style attestation token. Ten implemented security invariants all pass on the prototype: bootstrap identity cannot authorize control, issuance requires a valid fresh attestation, the certificate is bound to a freshly generated operational key, replayed evidence is rejected, an expired credential cannot issue commands, per-command scope matches issuance, a bad measurement yields only a narrowed safe-mode scope, a prior epoch cannot self-renew, and a copied prior operational key is contained at the next epoch. With per-command revalidation the post-expiry acceptance gap is $\Delta_{\text{expiry}} = -0.5\text{ s}$ (the last accepted adversarial command precedes expiry), against $+5.0\text{ s}$ without enforcement, where it grows to the cached session age. A fresh operational key is generated each epoch, so a copied key is useless after rotation. Table 8 lists the invariants, the identifier each carries in the released result file, and their outcomes. These are the invariants the prototype implements and tests; they are not a proof of the design, and properties outside this set are untested.

Overhead (C3)... On the workstation tier, over 500 iterations, the median software-path latencies (no hardware root of trust, no network transport) are 0.03 ms for key generation, 0.06 ms for attestation construction, 0.23 ms for a full attested issuance, and 2.2 ms for a real mutual-TLS handshake, with p99 tails within a few milliseconds. On the separate renewal harness the issuer sustains about 4900 renewals per second single-threaded. Renewal is therefore inexpensive on this platform. The measured operations are standard EC P-256 primitives dominated by a single ECDSA signature and verification, so per-issuance cost on a constrained inverter controller can be estimated from its public-key throughput; a hardware-backed measurement is declared future work rather than claimed here. These figures are workstation software-path timings and should not be read as deployment latencies.

Availability (C6)... Renewal is a full attested issuance, so its cost is the issuance cost above; the renewal safety margin $T_{\text{TTL}} - (T_{\text{renew,p99}} + T_{\text{net}})$ stays positive

Table 8: Security invariants implemented by the prototype (real X.509/mTLS). All ten pass; *Key* is the identifier emitted in `results/credsvc.json`, whose numbering skips I6 and runs to I11.

ID	Invariant	Key	Result
I1	Bootstrap identity cannot authorize control	I1	pass
I2	Issuance requires a fresh attestation	I2	pass
I3	Credential bound to a fresh public key	I3	pass
I4	Replayed evidence rejected	I4	pass
I5	Expired credential cannot issue a command	I5	pass
I6	Scope enforced per command	I7	pass
I7	Bad measurement yields degraded/denied scope	I8	pass
I8	Prior epoch cannot self-renew	I10	pass
I9	Copied prior key fails after rotation	I11	pass
I10	Active session/command bounded past expiry	I9	pass

at every tested lifetime down to five minutes, and a 100,000-device fleet re-mints in about 20 s single-threaded, so short lifetimes are latency-feasible. The availability risk is instead a verifier or issuer outage longer than the credential lifetime. Injecting verifier outages into the running service (renewal fails during the outage), fail-closed denial retains 0.77 of legitimate control availability over the outage window, a bounded grace period 0.83, and degraded-scope safe mode 1.0; control recovers as soon as the verifier returns. The injection is in-process; a networked or hardware outage, clock skew, and renewal storms remain for the full study.

Time-series containment and mechanism decomposition (C5).. The central physical result measures temporal containment directly, rather than as a product of a measured and a modeled factor. We run each policy as one time-series on the real IEEE 8500-node feeder: a compromised credential drives the DER from minute five, and its lifecycle then determines whether the malicious set-point keeps affecting the feeder. We integrate the real induced overvoltage area

over a 60-minute horizon, in p.u.-node-minutes, across three seeds (Fig. 2); values below are medians over those three runs. A legacy credential (B1) holds the feeder in violation for the whole horizon (integral 6956, no recovery). Holding the broad scope fixed but adding the CONTAINER lifecycle (A4) halves the integral to 3196 and the feeder recovers at credential expiry, which isolates the temporal effect of lifetime with session and command enforcement at equal scope. Removing session enforcement (A2) or command cleanup (A3) from that configuration returns the feeder to no recovery (7030), so each mechanism is necessary. Narrowing scope (B5) additionally bounds the instantaneous envelope, and the integral falls to 3.8. This single experiment gives the equal-scope decomposition the design intends: scope bounds the envelope, lifetime with enforcement bounds the duration, and neither alone suffices. Three seeds on one feeder at one operating state cannot establish an effect size; the confirmatory sweep is what tests this pattern.

Feeder consequence across operating states (C5). We run an export/overvoltage attack on the real IEEE 8500-node feeder (4876 buses, 8531 nodes, 1177 loads, 10.8 MW aggregate load at nominal multiplier) with 600 seeded rooftop-PV units of 12 kW each (7.2 MW), ten paired seeds, under three load states. Table 9 reports ΔJ_V as the median over seeds against the base case at the same load, with the interquartile range. Because the 8500 base has native undervoltage at its extremities, we report the induced *overvoltage* area the attack targets rather than a two-sided area that would credit the attack for lifting sagging nodes; this attack-specific endpoint was chosen after observing the base undervoltage, while the two-sided area remains the declared primary system-level endpoint. Under light load and high PV a legacy full-authorization compromise induces a median $\Delta J_V = 126.6$ (IQR 115.2–129.1); the CONTAINER narrowed scope keeps it within the ANSI band. Under normal load the medians are 6.6 against 0.13. Under heavy load the export attack cannot raise voltage above the band, so $\Delta J_V \leq 0$ regardless of policy. Several CONTAINER and heavy-load entries are slightly negative, because the narrowed reactive envelope marginally sup-

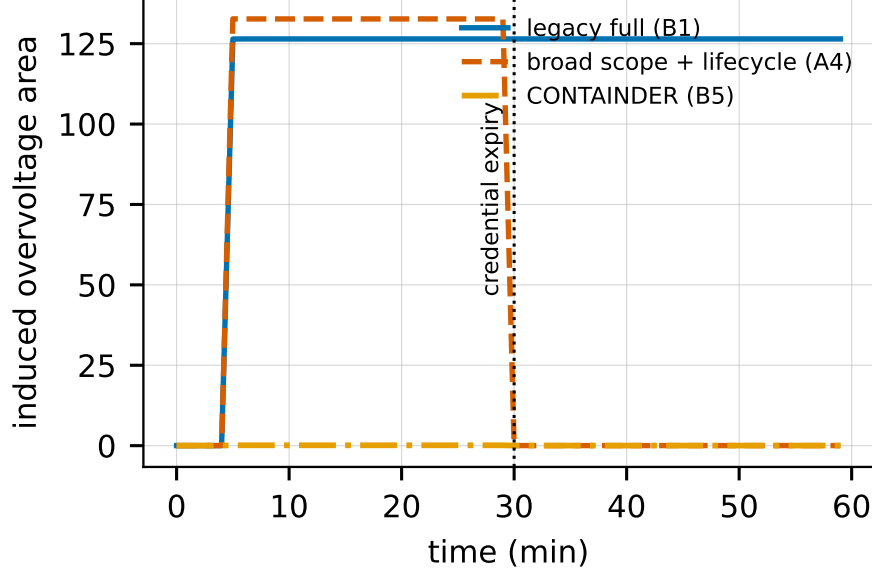


Figure 2: Time-series induced overvoltage area (p.u.-node-min) on the IEEE 8500-node feeder (light load; one representative seed of $n=3$; medians in the text are over all three). A legacy credential (B1) never recovers; at the same broad scope the CONTAINER lifecycle (A4) recovers at credential expiry; narrow scope (B5) additionally bounds the instantaneous envelope. The session-off and command-cleanup-off ablations track B1 and are omitted for clarity.

ports voltage at the base state. The ephemeral-only baseline equals the legacy one physically, since a short lifetime does not narrow scope; its advantage is temporal. The consequence is strongly state dependent, the physical-state separation of Proposition 3 on the real benchmark. The pilot reports medians and interquartile ranges only; the mixed-effects model, bootstrap intervals, and family-corrected tests of Section 8 require the confirmatory seed budget and are not computed here.

Penetration and robustness.. Induced overvoltage grows with PV penetration under a legacy full-authorization compromise, from 8 at 20% to 254 at 100% (five seeds), while the CONTAINER narrowed scope holds it near zero at every tested level (Fig. 3). The same containment holds across attack families

Table 9: Attack-induced overvoltage area ΔJ_V (p.u.-node, single-solution snapshot) on the IEEE 8500-node feeder: median [interquartile range] over $n=10$ paired seeds per cell. All 60 runs converged.

Operating state	Legacy full (B1)	CONTAINER (B5)
light load / high PV	126.60 [115.22, 129.14]	-0.014 [-0.014, -0.014]
normal	6.62 [4.49, 8.85]	0.13 [-0.02, 0.17]
heavy load	-0.20 [-0.28, -0.14]	-0.28 [-0.29, -0.26]

(Fig. 4). It also holds on a second public feeder: on the IEEE 123-bus system (three seeds) a legacy full-authorization compromise induces overvoltage under high PV penetration (induced area up to 2.2) that CONTAINER holds at zero, though the stiffer regulated 4.16 kV feeder requires higher penetration than the 8500 to breach the band, consistent with the feeder-dependence of Proposition 3.

Attack families.. The containment holds across attack families, not only the export attack (five seeds, light load). A legacy full-authorization compromise induces overvoltage areas of 122 (export-limit), 97 (volt-var, reactive injection alone), and 57 (volt-watt, active injection) that the CONTAINER narrowed scope reduces to zero in every case; for a curtailment-spam attack, narrowing cuts the per-node voltage variability from 0.012 to 0.004 p.u., a factor of three. Overvoltage is reachable through active or reactive authority, and narrowing scope reduces both to zero at the tested penetrations on this feeder.

Least privilege preserves legitimate utility (C5).. A scope that removed all control would contain the attack trivially, by disabling the device. CONTAINER’s operational scope is bounded volt-var support, not read-only. Under it a legitimate reactive voltage-support command is authorized while an active-power export command is denied; the attacker’s only remaining lever is bounded reactive, which induces overvoltage 0.04 against 126 under full authorization (three seeds, light load), whereas a read-only scope authorizes neither the legitimate nor the malicious command. The narrow scope therefore retains the most common legitimate DER function while bounding the attack, which distinguishes

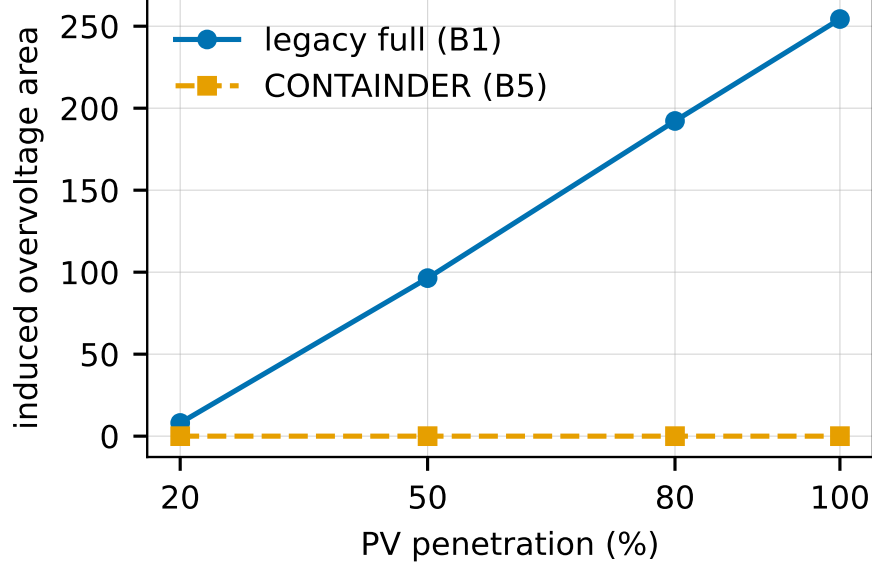


Figure 3: Induced overvoltage area (p.u.-node, snapshot) versus PV penetration (IEEE 8500, light load, $n=5$ seeds). Harm scales with penetration under the legacy baseline; containment is penetration-independent under CONTAINERD at the tested levels.

least privilege from denial of service.

Secondary summary: exposure across all six baselines (H1).. As a secondary summary across all six baselines, we report a proxy that multiplies the measured physical envelope by the modeled retained authority, $\Delta J_V \times \text{BR}_{\text{auth}}$ (Table 10); this is a physical-impact-times-duration quantity, not the flexibility-time BR_{exp} integral of the model, and the time-series above is the direct measurement it approximates. At full authorization scope, lengthening persistence from the ephemeral B3 (retained authority ≈ 10 h) to the legacy B1 (≈ 2 years) multiplies light-load exposure roughly $1700\times$, from 1.3×10^3 to 2.2×10^6 ; that ratio is set almost entirely by the modeled lifetime term, not by a measurement. At narrow scope the same change is inert: B2 and B5 are both near zero. The effect of persistence therefore depends on scope, consistent with the pre-registered persistence-by-scope hypothesis; because exposure is a product of a measured

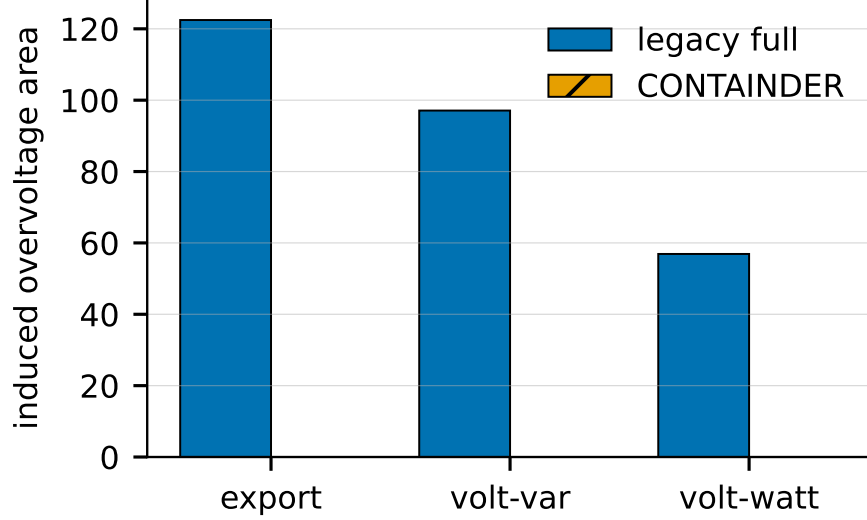


Figure 4: Induced overvoltage area (p.u.-node, snapshot) by attack family (IEEE 8500, light load, $n=5$ seeds). Narrowing scope contains overvoltage driven by active or reactive authority.

and a modeled factor, this pilot pattern does not by itself establish the pre-registered mixed-effects test over the full sweep. The full design B5 has lower exposure than both the ephemeral-only B3 and the attestation-only B4 (8.3×10^3), so neither half alone suffices. Mechanism ablations attribute the reduction: removing scope narrowing restores physical exposure (from near zero to 1.5×10^3), while fail-open renewal inflates retained authority from 12 h to 1.75×10^4 h. Scope narrowing bounds the physical envelope; attestation-gated renewal with session and command enforcement bounds how long it persists, the temporal containment the C2 copied-key and session-theft results measure.

Limitations.. These results are pilot results and we do not generalize them. Physical results come from two public feeders (a ten-seed IEEE 8500 sweep, a three-seed IEEE 8500 time-series, and a three-seed confirmatory IEEE 123 run) and a single OpenDSS solver, with no GridLAB-D cross-check and a fixed export attacker; the IEEE 9500-node system was obtained but did not converge in our OpenDSS build and is deferred to an appendix tier per the study’s

Table 10: Secondary exposure proxy $\Delta J_V \times \text{BR}_{\text{auth}}$ by baseline, in p.u.-node-hours (light load, IEEE 8500, $n=10$ seeds; ΔJ_V measured, BR_{auth} modeled from lifetime parameters, not measured). The time-series (Fig. 2) is the direct measurement.

Baseline	Scope	BR_{auth}	Exposure
B1 legacy full	full	$\sim 2 \text{ yr}$	2.2×10^6
B2 ACL-narrow	narrow	$\sim 2 \text{ yr}$	≈ 0
B3 ephemeral-only	full	$\sim 10 \text{ h}$	1.3×10^3
B4 attestation-only	reference	$\sim 14 \text{ d}$	8.3×10^3
B5 full CONTAINER	narrow	$\sim 12 \text{ h}$	≈ 0
B6 safe-mode	narrow	$\sim 12 \text{ h}$	≈ 0

pre-registered contingency. Retained-authority figures, and the exposure proxy built on them, are model outputs under assumed attestation and lifetime parameters, not measured field values. Overhead is workstation-only: there is no constrained-hardware or TEE measurement. The availability result injects verifier outages in-process rather than as networked or hardware failures, and clock skew and renewal storms are untested. Incremental deployment is by construction; interoperability against an unmodified IEEE 2030.5 endpoint is untested, and the exact clause-level delta between the 2018 and 2023 editions of the standard’s certificate-management text remains open pending access to the revised standard. CONTAINER bounds physical consequence under the evaluated scope configurations; the pre-registered sweep on two public feeders, with a cross-solver check, seasonal states, constrained hardware, and the full seed budget, is what would support quantitative claims beyond these.

10. Related Work

We position CONTAINER against ten strands (Table 11).

IEEE 2030.5 and CSIP security. The 2018 and 2023 editions of IEEE 2030.5 mandate mutual TLS with X.509 device certificates [7, 8], constrained for interconnection by the Common Smart Inverter Profile [9]. The closest prior work is the 2030.5 security tutorial of Passos et al. [6], a survey that proposes no

redesign, quantifies no feeder consequence, and formalizes no impact metric; Qi et al. survey the broader DER and smart-inverter surface [15]. The Sandia analysis supplies the revocation constraints we respect [1].

DER and smart-inverter attacks. High-wattage IoT botnets can move the grid [16, 17]; on the DER side, inverter attacks destabilize grid and market [18] and distribution voltage control is attackable under high PV [19], while the SUN:DOWN disclosure catalogs fleet-scale inverter vulnerabilities [20]. We tie the attack surface to the credential lifecycle rather than assuming device compromise.

Distribution-grid cyber-physical impact. False-data-injection work quantifies compromise consequence [21, 22, 23], grounded by the 2015 Ukraine incident [24] and quantitative risk formulations [25]; our feeder method is supporting, not novel.

Short-lived certificates and PKI lifecycle. ACME [26] and Let’s Encrypt [27] automate issuance, SCEP [28] is the incumbent device enrollment, and HTTPS-ecosystem measurement quantifies the lifecycle problem [29]; we adopt short lifetimes as one link of a chain.

Hardware-bound identity. Secure device identity [10], firmware TPM [30], and hardware DICE [31] root our bootstrap layer.

Remote attestation. We use the RATS architecture [12], the Entity Attestation Token [11], and BRSKI [32], on established principles [33], adding fresh-key binding.

Attack-graph and cyber-physical metrics. Logic-based [2, 34, 35], probabilistic and Bayesian [3, 36, 37], and k -zero-day [4] metrics are static-snapshot and cyber-only; Section IV shows what reachability-only reading omits, positioning our model as complementary.

Co-simulation. HELICS federates the cyber and grid models [38, 39] with GridLAB-D on the power side [40].

DER authorization. IEEE 1547 [41] defines the DER functions, DERMS perform feeder voltage management [42], and role-based access control [43] abstracts the scoping we narrow and enforce.

Table 11: Positioning against representative prior work. y = yes, n = no, p = partial, – = n/a.

Work	2030.5	Scope	Time	Phys.	Attest.	Proto.	Feeder
Attack-graph metrics [2, 3, 4]	n	p	n	n	n	–	n
2030.5 security survey [6]	y	p	n	n	n	n	n
Attestation building blocks [12, 11, 10]	n	p	p	p	y	p	n
CONTAINERD (this work)	y	y	y	y	y	p*	p*

y = addressed; p = partial; n = not addressed; – = not applicable. *Partial: a prototype and a pilot feeder evaluation are reported in Section 9; native-client interoperability, constrained hardware, and the full pre-registered sweep are not yet done.

Revocation at scale. Web-PKI revocation delivery is gap-ridden [44], scalable revocation remains an open problem [45, 46], and even OCSP Must-Staple adoption is weak [47], which motivates containment by short-lived credentials rather than by revocation.

11. Ethics and Responsible Disclosure

This work studies the consequences of credential compromise in order to bound them, and it carries a corresponding responsibility. All experiments use synthetic and lab-generated certificates. We use no real vendor keys or secrets, we test against no production DER fleet or any internet-reachable device, and we build no exploit tooling bound to a specific vendor product. The malicious dispatch programs exist only inside the feeder co-simulation and are never emitted to hardware.

The physical-consequence results describe what a compromised but protocol-conformant credential can already do under the deployed standard; they do not introduce a new vulnerability so much as measure an existing exposure that the standard’s prohibition on revocation leaves unmitigated. Where results identify

a concrete deployment weakness, we will follow coordinated disclosure with the relevant standards body and affected implementers before public release, and we will time any artifact release accordingly. The redesign and its migration path are offered as the constructive counterpart to the measurement: the point of quantifying the blast radius is to shrink it.

12. Limitations and Conclusion

Limitations.. The boundaries of the evaluation are stated once, next to the results they bound, at the end of Section 9: two public feeders and a single solver, modeled rather than measured retained authority, workstation-only overhead, in-process availability injection, untested interoperability, and the open clause-level delta between the 2018 and 2023 editions of the standard. Two further boundaries are proper to the model rather than to the measurements. The authorization graphs used by the engine are synthetic, because real utility authorization graphs are not public; we mitigate this with a released, parameterized generator and by treating access-model permissiveness as an ablated variable rather than a fixed assumption. And our claims about revocation rest on the primary Sandia analysis rather than on a clause-level reading of the revised standard.

Conclusion.. Credential compromise in IEEE 2030.5 is not well described by how many nodes an adversary can reach. It is described by how much physical capacity those nodes command, how long the adversary keeps it, and what the feeder does in response. We formalized these as four impact dimensions, showed that reachability-only measurement omits scope, time, and feeder state, and built a redesign that shrinks them using attested, short-lived, scope-bound operational credentials with non-renewal as containment. A pilot end-to-end evaluation is consistent with the design: the ten implemented security invariants pass, per-command enforcement contains authority at expiry, and at the light- and normal-load states where a legacy credential drives the feeder outside the ANSI band, narrowing scope keeps the overvoltage a compromise induces on

the IEEE 8500-node feeder within it, with the full evaluation still to come. The model is the lever: it says which quantities a DER-authorization defense must move, and it rejects the measures that only move reach.

Data availability

The analysis engine, the X.509/mutual-TLS credential service, the OpenDSS feeder experiment scripts, the pre-registered scenario matrix with its recorded hash, and the result files supporting this study will be released in a public repository upon publication. The IEEE 8500-node and IEEE 123-bus test feeders used in the evaluation are publicly available from the referenced OpenDSS distributions.

Declaration of competing interest

The author declares that he has no known competing financial interests or personal relationships that could have appeared to influence the work reported in this paper.

CRedit authorship contribution statement

Huan Bui: Conceptualization, Methodology, Software, Validation, Formal analysis, Investigation, Data curation, Writing – original draft, Writing – review and editing, Visualization.

References

- [1] J. Obert, P. Cordeiro, J. Johnson, G. Lum, T. Tansy, M. Pala, R. Ih, Recommendations for trust and encryption in DER interoperability standards, Tech. Rep. SAND2019-1490, Sandia National Laboratories, Albuquerque, NM (Feb. 2019).

- [2] X. Ou, S. Govindavajhala, A. W. Appel, MulVAL: A logic-based network security analyzer, in: 14th USENIX Security Symposium (USENIX Security 05), USENIX Association, 2005.
- [3] L. Wang, T. Islam, T. Long, A. Singhal, S. Jajodia, An attack graph-based probabilistic security metric, in: Data and Applications Security XXII (DBSec 2008), Vol. 5094 of Lecture Notes in Computer Science, Springer, 2008, pp. 283–296. doi:10.1007/978-3-540-70567-3_22.
- [4] L. Wang, S. Jajodia, A. Singhal, P. Cheng, S. Noel, k-zero day safety: A network security metric for measuring the risk of unknown vulnerabilities, IEEE Transactions on Dependable and Secure Computing 11 (1) (2014) 30–44. doi:10.1109/TDSC.2013.24.
- [5] R. F. Arritt, R. C. Dugan, The IEEE 8500-node test feeder, in: IEEE PES T&D 2010, IEEE, 2010, pp. 1–6. doi:10.1109/TDC.2010.5484381.
- [6] D. Passos, C. de Sousa, R. C. Gomes, D. F. de Assis, F. G. d. O. Passos, C. Albuquerque, A tutorial and security overview on the IEEE 2030.5-2018 standard, IEEE Communications Surveys & Tutorials 27 (6) (2025) 3615–3640. doi:10.1109/COMST.2025.3532110.
- [7] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, IEEE Standards Association (2018). doi:10.1109/IEEESTD.2018.8608044.
- [8] IEEE, IEEE Standard for Smart Energy Profile Application Protocol, IEEE Standards Association; published Dec. 2024 (2023). doi:10.1109/IEEESTD.2024.10785536.
- [9] SunSpec Alliance, Common Smart Inverter Profile (CSIP): IEEE 2030.5 Implementation Guide for Smart Inverters, version 2.1 Edition, released 16 March 2018; supports CA Rule 21 Phase 2 (Mar. 2018).
- [10] IEEE, IEEE Standard for Local and Metropolitan Area Networks—Secure Device Identity (2018). doi:10.1109/IEEESTD.2018.8423794.

- [11] L. Lundblade, G. Mandyam, J. O'Donoghue, C. Wallace, The entity attestation token (EAT), RFC 9711, Internet Engineering Task Force (IETF) (Apr. 2025). doi:10.17487/RFC9711.
- [12] H. Birkholz, D. Thaler, M. Richardson, N. Smith, W. Pan, Remote ATtestation procedures (RATS) architecture, RFC 9334, Internet Engineering Task Force (IETF) (Jan. 2023). doi:10.17487/RFC9334.
- [13] A. Anderson, S. Vadari, J. Barr, S. Poudel, A. Dubey, T. McDermott, R. Podmore, Introducing the 9500 node distribution test system to support advanced power applications: An operations-focused approach, Tech. Rep. PNNL-33471, Pacific Northwest National Laboratory (PNNL), u.S. DOE Office of Scientific and Technical Information (2022). doi:10.2172/1922914.
- [14] National Electrical Manufacturers Association (NEMA), American National Standard for Electric Power Systems and Equipment—Voltage Ratings (60 Hz), revision of ANSI C84.1-2016; reaffirmed 2025 (2020).
- [15] J. Qi, A. Hahn, X. Lu, J. Wang, C.-C. Liu, Cybersecurity for distributed energy resources and smart inverters, IET Cyber-Physical Systems: Theory & Applications 1 (1) (2016) 28–39. doi:10.1049/iet-cps.2016.0018.
- [16] S. Soltan, P. Mittal, H. V. Poor, BlackIoT: IoT botnet of high wattage devices can disrupt the power grid, in: 27th USENIX Security Symposium (USENIX Security 18), USENIX Association, 2018, pp. 15–32.
- [17] T. Shekari, A. A. Cárdenas, R. Beyah, MaDIoT 2.0: Modern high-wattage IoT botnet attacks and defenses, in: 31st USENIX Security Symposium (USENIX Security 22), USENIX Association, 2022, pp. 3539–3556.
- [18] X. Hui, S. Karumba, S. C.-K. Chau, M. Ahmed, Destabilizing power grid and energy market by cyberattacks on smart inverters, in: Proceedings of the 16th ACM International Conference on Future and Sustainable Energy Systems (e-Energy '25), ACM, 2025, pp. 136–151. doi:10.1145/3679240.3734613.

- [19] Y. Isozaki, S. Yoshizawa, Y. Fujimoto, H. Ishii, I. Ono, T. Onoda, Y. Hayashi, Detection of cyber attacks against voltage control in distribution power grids with PVs, *IEEE Transactions on Smart Grid* 7 (4) (2016) 1824–1835. doi:10.1109/TSG.2015.2427380.
- [20] Forescout Vedere Labs, SUN:DOWN: Destabilizing the grid via orchestrated exploitation of solar power systems, Vulnerability research report, Forescout Technologies, industry (non-peer-reviewed) report; landing page titled “SUN:DOWN Vulnerability Research Report.” 46 CVEs across Sun-grow, Growatt, SMA (Mar. 2025).
- [21] Y. Liu, P. Ning, M. K. Reiter, False data injection attacks against state estimation in electric power grids, in: *Proceedings of the 16th ACM Conference on Computer and Communications Security (CCS '09)*, ACM, 2009, pp. 21–32. doi:10.1145/1653662.1653666.
- [22] R. Deng, G. Xiao, R. Lu, H. Liang, A. V. Vasilakos, False data injection on state estimation in power systems—attacks, impacts, and defense: A survey, *IEEE Transactions on Industrial Informatics* 13 (2) (2017) 411–423. doi:10.1109/TII.2016.2614396.
- [23] G. Liang, J. Zhao, F. Luo, S. R. Weller, Z. Y. Dong, A review of false data injection attacks against modern power systems, *IEEE Transactions on Smart Grid* 8 (4) (2017) 1630–1638. doi:10.1109/TSG.2015.2495133.
- [24] G. Liang, S. R. Weller, J. Zhao, F. Luo, Z. Y. Dong, The 2015 Ukraine blackout: Implications for false data injection attacks, *IEEE Transactions on Power Systems* 32 (4) (2017) 3317–3318. doi:10.1109/TPWRS.2016.2631891.
- [25] A. Teixeira, K. C. Sou, H. Sandberg, K. H. Johansson, Secure control systems: A quantitative risk management approach, *IEEE Control Systems Magazine* 35 (1) (2015) 24–45. doi:10.1109/MCS.2014.2364709.

- [26] R. Barnes, J. Hoffman-Andrews, D. McCarney, J. Kasten, Automatic certificate management environment (ACME), RFC 8555, Internet Engineering Task Force (IETF) (Mar. 2019). doi:10.17487/RFC8555.
- [27] J. Aas, R. Barnes, B. Case, Z. Durumeric, P. Eckersley, A. Flores-López, J. A. Halderman, J. Hoffman-Andrews, J. Kasten, E. Rescorla, S. Schoen, B. Warren, Let’s encrypt: An automated certificate authority to encrypt the entire web, in: Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security (CCS ’19), ACM, 2019, pp. 2473–2487. doi:10.1145/3319535.3363192.
- [28] P. Gutmann, Simple certificate enrolment protocol (SCEP), RFC 8894, Internet Engineering Task Force (IETF) (Sep. 2020). doi:10.17487/RFC8894.
- [29] Z. Durumeric, J. Kasten, M. Bailey, J. A. Halderman, Analysis of the HTTPS certificate ecosystem, in: Proceedings of the 2013 Internet Measurement Conference (IMC ’13), ACM, 2013, pp. 291–304. doi:10.1145/2504730.2504755.
- [30] H. Raj, S. Saroiu, A. Wolman, R. Aigner, J. Cox, P. England, C. Fenger, K. Kinshumann, J. Löser, D. Mattoon, M. Nyström, D. Robinson, R. Spiger, S. Thom, D. Wooten, fTPM: A software-only implementation of a TPM chip, in: 25th USENIX Security Symposium (USENIX Security 16), USENIX Association, 2016, pp. 841–856.
- [31] L. Jäger, R. Petri, DICE harder: A hardware implementation of the device identifier composition engine, in: Proceedings of the 15th International Conference on Availability, Reliability and Security (ARES ’20), ACM, 2020, pp. 1–8. doi:10.1145/3407023.3407028.
- [32] M. Pritikin, M. Richardson, T. Eckert, M. Behringer, K. Watsen, Bootstrapping remote secure key infrastructure (BRSKI), RFC 8995, Internet Engineering Task Force (IETF) (May 2021). doi:10.17487/RFC8995.

- [33] G. Coker, J. Guttman, P. Loscocco, A. Herzog, J. Millen, B. O’Hanlon, J. Ramsdell, A. Segall, J. Sheehy, B. Sniffen, Principles of remote attestation, *International Journal of Information Security* 10 (2) (2011) 63–81. doi:10.1007/s10207-011-0124-7.
- [34] P. Ammann, D. Wijesekera, S. Kaushik, Scalable, graph-based network vulnerability analysis, in: *Proceedings of the 9th ACM Conference on Computer and Communications Security (CCS ’02)*, ACM, 2002, pp. 217–224. doi:10.1145/586110.586140.
- [35] S. Jajodia, S. Noel, B. O’Berry, Topological analysis of network attack vulnerability, in: *Managing Cyber Threats: Issues, Approaches, and Challenges*, Vol. 5 of *Massive Computing*, Springer, 2005, pp. 247–266. doi:10.1007/0-387-24230-9_9.
- [36] M. Frigault, L. Wang, Measuring network security using bayesian network-based attack graphs, in: *2008 32nd Annual IEEE International Computer Software and Applications Conference (COMPSAC)*, IEEE, 2008, pp. 698–703. doi:10.1109/COMPSAC.2008.88.
- [37] N. Poolsappasit, R. Dewri, I. Ray, Dynamic security risk management using bayesian attack graphs, *IEEE Transactions on Dependable and Secure Computing* 9 (1) (2012) 61–74. doi:10.1109/TDSC.2011.34.
- [38] T. D. Hardy, B. Palmintier, P. L. Top, D. Krishnamurthy, J. C. Fuller, HELICS: A co-simulation framework for scalable multi-domain modeling and analysis, *IEEE Access* 12 (2024) 24325–24347. doi:10.1109/ACCESS.2024.3363615.
- [39] B. Palmintier, D. Krishnamurthy, P. Top, S. Smith, J. Daily, J. Fuller, Design of the HELICS high-performance transmission-distribution-communication-market co-simulation framework, in: *2017 Workshop on Modeling and Simulation of Cyber-Physical Energy Systems (MSCPES)*, IEEE, 2017, pp. 1–6. doi:10.1109/MSCPES.2017.8064542.

- [40] D. P. Chassin, K. Schneider, C. Gerkensmeyer, GridLAB-D: An open-source power systems modeling and simulation environment, in: 2008 IEEE/PES Transmission and Distribution Conference and Exposition, IEEE, 2008, pp. 1–5. doi:10.1109/TDC.2008.4517260.
- [41] IEEE, IEEE Standard for Interconnection and Interoperability of Distributed Energy Resources with Associated Electric Power Systems Interfaces (2018). doi:10.1109/IEEESTD.2018.8332112.
- [42] I. Rahman, N. Selak, E. Paaso, Distributed energy resource management system (DERMS) solution for feeder voltage management for utility integrated DERs, in: 2021 IEEE Power & Energy Society Innovative Smart Grid Technologies Conference (ISGT), IEEE, 2021, pp. 1–5. doi:10.1109/ISGT49243.2021.9372281.
- [43] R. S. Sandhu, E. J. Coyne, H. L. Feinstein, C. E. Youman, Role-based access control models, *Computer* 29 (2) (1996) 38–47. doi:10.1109/2.485845.
- [44] Y. Liu, W. Tome, L. Zhang, D. Choffnes, D. Levin, B. Maggs, A. Mislove, A. Schulman, C. Wilson, An end-to-end measurement of certificate revocation in the web’s PKI, in: Proceedings of the 2015 Internet Measurement Conference (IMC ’15), ACM, 2015, pp. 183–196. doi:10.1145/2815675.2815685.
- [45] J. Larisch, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, C. Wilson, CRLite: A scalable system for pushing all TLS revocations to all browsers, in: 2017 IEEE Symposium on Security and Privacy (SP), IEEE, 2017, pp. 539–556. doi:10.1109/SP.2017.17.
- [46] T. Smith, L. Dickinson, K. Seamons, Let’s revoke: Scalable global certificate revocation, in: Proceedings 2020 Network and Distributed System Security Symposium (NDSS), Internet Society, 2020. doi:10.14722/ndss.2020.24084.

- [47] T. Chung, J. Lok, B. Chandrasekaran, D. Choffnes, D. Levin, B. M. Maggs, A. Mislove, J. Rula, N. Sullivan, C. Wilson, Is the web ready for OSCP must-staple?, in: Proceedings of the Internet Measurement Conference 2018 (IMC '18), ACM, 2018, pp. 105–118. doi:10.1145/3278532.3278543.